

Software Requirements Specification (SRS)

Technical architecture, functional requirements, data model, security, AI controls, APIs, quality and operations

Product: Closecraft AI Revenue Operating System | Release: MVP / Validation Build | Status: Production engineering baseline | Date: 6 October 2026

Core principle: AI handles speed, repetition and scale. Humans handle judgement, negotiation and high-value sales decisions.

1. Purpose and Scope

This SRS defines the implementable software requirements for the Closecraft MVP. It is technology-agnostic where practical and prescriptive where correctness, security or operability requires a contract. The system is a multi-tenant SaaS with a responsive web client, APIs, asynchronous jobs, messaging/calendar integrations and AI-assisted qualification.

2. System Context and Architecture

Logical architecture: Web Client -> API/Application Layer -> Authentication/RBAC -> Domain Services -> Relational Database + Durable Queue/Scheduler -> Provider Adapters -> AI Orchestration -> Analytics/Observability.

- Frontend: responsive web application, desktop-first for operations and mobile-capable for review/reply.
- Backend: stateless application services with versioned APIs and server-side authorisation.
- Database: relational system of record with workspace/tenant ownership on all tenant data.
- Queue: durable asynchronous processing for webhooks, messaging, AI, follow-up, calendar callbacks and retries.
- Integrations: provider-specific adapters isolate external schemas from domain logic.
- AI layer: structured-output orchestration, prompt/config versioning, provider abstraction, evaluation and usage telemetry.

3. Domain Model

Entity	Key Fields / Relationships
Workspace	id, name, timezone, status, plan, configuration, timestamps
User	id, auth identity, name, email, status
Membership	workspace_id, user_id, role, permission overrides
Lead	workspace_id, identity, source, owner, stage, score, consent, timestamps
Conversation	workspace_id, lead_id, channel, automation_state
Message	conversation_id, direction, sender_type, provider_id, content/ref, delivery state, timestamps
QualificationProfile	workspace_id, criteria, questions, weights, thresholds, version, active
Assessment	lead_id, profile_version, factors, score, confidence, evidence refs, recommendation
AIAction	lead_id, type, proposed payload, confidence, policy trigger, reviewer, state
FollowUp	lead_id, conversation_id, due_at, attempt, policy_version, state
Appointment	lead_id, owner, provider/calendar refs, start/end, timezone,

	state
KnowledgeItem	workspace_id, type, content/ref, state, version
Integration	workspace_id, provider, credential_ref, scopes, health, state
AuditEvent	workspace_id, actor, action, object, result, timestamp, metadata
Outcome	lead_id, won/lost, value, currency, reason, timestamp

4. Functional Requirements

ID	Area	Requirement	Pri.
FR-001	Workspace	The system shall create isolated customer workspaces and bind all tenant-owned records to exactly one workspace.	P0
FR-002	Auth	The system shall authenticate users and maintain secure sessions.	P0
FR-003	RBAC	The system shall enforce role/permission checks server-side for every protected operation.	P0
FR-004	Users	Owners/Admins shall invite, deactivate and assign roles to workspace users.	P0
FR-005	Lead Capture	The system shall ingest leads via WhatsApp, webhook/API and manual/import paths.	P0
FR-006	Idempotency	Inbound webhooks shall be idempotent and duplicate delivery shall not duplicate domain actions.	P0
FR-007	Dedupe	The system shall normalise lead identifiers and apply deterministic duplicate handling.	P0
FR-008	Timeline	The system shall maintain a chronological lead timeline of messages, AI assessments, assignments, reviews, appointments and outcomes.	P0
FR-009	Messaging	The system shall send/receive WhatsApp messages through an approved provider and persist provider delivery states.	P0
FR-010	Consent	The system shall check channel opt-out/consent state	P0

		before scheduling or sending automated outbound messages.	
FR-011	Qualification Config	Admins shall configure questions, criteria, disqualifiers, factor weights and thresholds without code changes.	P0
FR-012	Assessment	The system shall produce structured qualification assessments with factors, unknowns, score, confidence, evidence references and recommended action.	P0
FR-013	Human Review	The system shall create review items when configured risk, confidence, value, topic or action thresholds are met.	P0
FR-014	Review Actions	Authorised reviewers shall approve, edit, reject, assign or handle proposed AI actions manually.	P0
FR-015	Follow-up	The system shall schedule follow-up with configurable delays, attempts, quiet hours and stop conditions.	P0
FR-016	Stop Conditions	Replies, opt-outs, conversion, loss, appointment or human takeover shall cancel/recalculate incompatible pending automation.	P0
FR-017	Assignment	The system shall support lead ownership and maintain assignment history.	P0
FR-018	Calendar	The system shall connect at least one calendar provider and retrieve availability.	P0
FR-019	Booking	The system shall create appointments and only mark them confirmed after provider confirmation.	P0
FR-020	Dashboard	The dashboard shall show operational KPIs and a prioritised attention queue.	P0
FR-021	Search	Users shall search permitted leads and conversations and filter by owner, source, stage and status.	P0
FR-022	Knowledge	Admins shall maintain approved tenant-scoped knowledge used for grounded AI responses.	P1

FR-023	Integrations	The system shall expose provider connection status, health and recoverable errors.	P0
FR-024	Audit	The system shall record material human, AI, configuration, integration and security events.	P0
FR-025	Outcomes	Users shall record Won/Lost and optional value/currency/reason.	P0
FR-026	Analytics	The system shall calculate core validation metrics and export pilot data.	P0
FR-027	Billing	The system shall represent plan, usage and payment state sufficient for paid pilots.	P1
FR-028	Notifications	The system shall notify authorised users of review-required, hot lead, appointment and integration failure events.	P1

5. AI and Model Requirements

ID	Requirement
AI-001	All AI outputs used by application logic shall conform to validated structured schemas.
AI-002	Invalid model output shall fail closed, retry safely or route to human review.
AI-003	Prompts, model identifiers and qualification configuration shall be versioned and traceable per assessment.
AI-004	The model shall distinguish explicit prospect evidence from inference; absent data shall remain unknown.
AI-005	AI-generated outbound content shall be bounded by approved workspace knowledge and communication policy.
AI-006	Discounts, commitments, sensitive actions and other restricted operations shall be blocked by deterministic policy unless explicitly authorised.
AI-007	Low confidence shall trigger clarification or human review according to policy.
AI-008	The platform shall record provider/model, latency, usage/cost and result status for each material AI job.
AI-009	AI provider abstraction shall allow model substitution without changing core domain contracts.
AI-010	Tenant-scoped retrieval shall prevent cross-workspace knowledge access.

AI-011	Prompt injection in prospect messages or documents shall not override system policy, permissions or tool constraints.
AI-012	Private chain-of-thought shall not be stored or exposed; store concise decision rationale and evidence references instead.

6. Security and Privacy Requirements

ID	Requirement
SEC-001	Encrypt traffic using current TLS and protect sensitive stored data with platform-appropriate encryption.
SEC-002	Store provider/API secrets in a secrets manager or encrypted credential store; never expose them to the browser or normal logs.
SEC-003	Enforce tenant isolation server-side and test horizontal/vertical privilege escalation.
SEC-004	Apply least-privilege RBAC to Owner, Admin, Sales Manager, Closer, Setter and Viewer.
SEC-005	Use secure session management, CSRF protection where applicable and appropriate authentication rate limits.
SEC-006	Validate webhook signatures where supported and implement replay/idempotency protection.
SEC-007	Validate and sanitise inputs and encode outputs to mitigate injection/XSS risks.
SEC-008	Maintain tamper-resistant audit records for material administrative and approval actions.
SEC-009	Support data export/deletion and configurable retention aligned with applicable obligations.
SEC-010	Minimise PII sent to AI providers and document subprocessor/data handling configuration.
SEC-011	Redact credentials, tokens and sensitive payloads from logs and error reports.
SEC-012	Run dependency, secret, static analysis and vulnerability scanning before production release.

7. Non-Functional Requirements

ID	Category	Requirement / Target
NFR-001	Availability	Pilot target $\geq 99.5\%$ monthly application availability, excluding announced maintenance and upstream provider outages.
NFR-002	Latency	Interactive non-AI API p95 target ≤ 500 ms under expected pilot load.

NFR-003	AI UX	AI operations over 2 seconds run asynchronously and expose meaningful processing state.
NFR-004	Webhook	Acknowledge valid inbound webhooks quickly and perform durable work asynchronously.
NFR-005	Scalability	Stateless services and queue workers shall scale horizontally; no global tenant state.
NFR-006	Reliability	Transient external failures use bounded exponential backoff and dead-letter handling.
NFR-007	Accessibility	Core user journeys target WCAG 2.2 AA.
NFR-008	Responsive	Dashboard, lead detail, AI review, reply and appointments function on modern mobile widths.
NFR-009	Observability	Monitor queue depth, webhook/message failures, AI errors, latency, integration health and auth anomalies.
NFR-010	Backup	Automated database backups and documented restore test before production pilot.
NFR-011	Integrity	Use transactions/idempotency where duplicate execution could create messages, bookings or outcomes.
NFR-012	Cost	Per-workspace AI/messaging usage telemetry, caps and alerts protect gross margin.

8. RBAC Baseline

Capability	Owner/Admin	Manager	Closer/Setter	Viewer
Workspace settings	Full	Limited	No	No
Users/roles	Full	View/limited	No	No
Leads/conversations	Full	Full	Assigned/permitted	Read permitted
AI approvals	Full	Full	Assigned/permitted	No
Qualification policy	Full	View	View	View
Integrations/billing	Full	Health/read	No	No
Analytics	Full	Full	Own/team	Read permitted
Audit logs	Full	Operational read	Own actions	No

9. State Machines

- Lead: New -> Engaged -> Qualifying -> Qualified -> Appointment -> Opportunity -> Won/Lost.
- AI Action: Proposed -> Auto-approved or Needs Review -> Approved/Edited/Rejected/Expired -> Executed/Failed.
- Follow-up: Scheduled -> Due -> Sent -> Replied/Rescheduled/Cancelled/Exhausted/Failed.
- Appointment: Proposed -> Pending Provider -> Confirmed -> Completed/Rescheduled/Cancelled/No-show.
- Integration: Disconnected -> Connecting -> Connected -> Degraded -> Error -> Disconnected.

10. API and Integration Contract Principles

- Version public/internal APIs and validate request/response schemas.
- Use provider signature verification and idempotency for inbound callbacks.
- Use idempotency keys for retryable create operations such as outbound messages and appointments.
- Translate provider payloads inside adapters; domain services must not depend on raw provider schemas.
- Persist provider correlation IDs for traceability.
- Do not report provider-dependent success until provider acknowledgement is received.
- Return stable domain error codes that distinguish validation, authorisation, conflict, provider failure and retryable failure.

11. Core API Surface (Logical)

Method / Resource	Purpose
POST /v1/leads	Create lead manually/API.
GET /v1/leads	List/search/filter permitted leads.
GET/PATCH /v1/leads/{id}	Read/update permitted lead.
GET /v1/leads/{id}/timeline	Read lead activity timeline.
POST /v1/conversations/{id}/messages	Send authorised message.
POST /v1/webhooks/{provider}	Receive provider events idempotently.
POST /v1/leads/{id}/assessments	Request/recompute qualification assessment.
GET/PATCH /v1/ai-actions/{id}	Read/review proposed AI action.
POST /v1/leads/{id}/assign	Assign owner.
GET /v1/calendars/availability	Retrieve provider availability.
POST /v1/appointments	Create provider-backed appointment.
GET/PATCH /v1/settings/qualification	Read/update qualification configuration.
GET /v1/analytics/summary	Retrieve workspace KPI summary.

12. Analytics Event Contract

Event	Minimum Properties
lead.created	workspace_id, lead_id, source, timestamp
message.received / sent	lead_id, conversation_id, channel, sender_type, delivery_state
qualification.completed	lead_id, profile_version, score, confidence, factor_summary
ai_action.proposed / reviewed / executed	lead_id, action_type, confidence, reviewer/outcome
followup.scheduled / sent / cancelled	lead_id, policy_version, attempt, reason
appointment.booked / changed	lead_id, owner_id, status, time, provider
lead.assigned	lead_id, previous_owner, new_owner
outcome.recorded	lead_id, outcome, value, currency, reason
integration.health_changed	provider, previous_state, current_state

13. Error Handling and Resilience

- User-facing errors explain what failed, what remains safe and the next action.
- Transient background failures retry automatically with bounded backoff.
- Repeated failures enter dead-letter/review state with operational visibility.
- Duplicate callbacks do not create duplicate domain state.
- AI failure degrades to manual handling.
- Provider outages do not corrupt local lead/conversation state.
- Stale AI actions are revalidated before execution.

14. Testing and Quality Gates

Layer	Minimum Gate
Unit	Domain rules, scoring/routing, stop conditions, permissions and state transitions.
Integration	Messaging, calendar, auth, database, queue and AI structured-output validation.
Contract	Webhook schemas, provider fixtures and API schema compatibility.
E2E	Onboarding, inbound lead, qualification, review, follow-up, assignment, booking, opt-out and outcome.
Security	RBAC/IDOR, tenant isolation, secrets, spoof/replay, injection and dependency scanning.
AI Evaluation	Representative qualification set, escalation cases, unsupported claims and hallucination checks.
Load	Webhook bursts, queue processing and dashboard reads at forecast plus safety margin.

Recovery	Provider outage, queue retry, failed AI call, calendar failure and database restore exercise.
----------	---

15. Deployment and Operations

- Separate development, staging and production environments.
- Infrastructure and database migrations are version-controlled and repeatable.
- CI gates include tests, lint/static analysis, secret/dependency checks and build verification.
- Production changes use controlled deployment with rollback capability.
- Operational dashboards cover API health, queue depth, provider failures, AI errors/cost, database health and authentication anomalies.
- Define incident ownership, escalation path, backup restoration procedure and provider outage runbooks.

16. Definition of Done

- Acceptance criteria satisfied and tests pass.
- Tenant scoping and server-side authorisation verified.
- Loading, empty, success and error states implemented.
- Audit and telemetry added for material operations.
- Accessibility checks pass for affected core flow.
- No known P0/P1 security defect remains open.
- Operational/support documentation is sufficient for another engineer to deploy and diagnose the feature.

17. Production Readiness Gate

Area	Required Before Paid Pilot
Infrastructure	Production environment, managed DB, backups, secret management, HTTPS and monitoring.
Messaging	Approved business messaging integration, callbacks and policy-compliant templates where required.
AI	Production credentials, retry/fallback policy, cost limits, evaluation baseline and prompt versions.
Security	RBAC/tenant tests, rate limits, audit log, privacy/retention process and incident contact.
Operations	Support path, integration-health visibility, dead-letter/retry procedure and runbooks.
Commercial	Plan/usage rules, terms/privacy notices and billing/invoicing process.
Analytics	Baseline and post-launch metrics available per pilot workspace.